

SÉCURITÉ DES SYSTÈMES

M1 CSIA (S2)

M. MEDEDJEL

2025-2026

COURS 4 (CHAPITRE II):

LOGICIELS MALVEILLANTS (MALWARES)

INTRODUCTION

Les logiciels malveillants, ou « malwares », constituent l'une des catégories de menaces les plus importantes pour les systèmes informatiques.

Il s'agit des programmes dont l'objectif est de compromettre l'intégrité, la confidentialité ou la disponibilité des systèmes informatiques, des réseaux ou des appareils.

INTRODUCTION

Ce chapitre présente la diversité des menaces liées aux **logiciels malveillants** (ou **malwares**) ainsi que les principales contre-mesures.

Nous commencerons par décrire les **différents types de malwares**, en les classant d'abord selon leur **mode de propagation**, puis selon leurs **actions ou charges utiles** qu'ils exécutent une fois la cible atteinte.

Nous terminerons par un panorama des mécanismes de défense à mettre en place pour s'en protéger..

CLASSIFICATION DES LOGICIELS MALVEILLANTS

Les principaux mécanismes de propagation des malwares incluent :

- **L'infection** de fichiers exécutables ou interprétés par des virus, qui peuvent ensuite se propager vers d'autres systèmes ;
- L'exploitation de **vulnérabilités logicielles**, en local ou via réseau, par des vers ou des téléchargements furtifs qui permettent au code malveillant de se répliquer ;
- Les attaques **d'ingénierie sociale**, qui incitent les utilisateurs à contourner les mécanismes de sécurité, par exemple en installant des chevaux de Troie ou en répondant à des tentatives de phishing.

CLASSIFICATION DES LOGICIELS MALVEILLANTS

Les principales actions réalisées par un logiciel malveillant une fois la cible atteinte peuvent inclure :

- La corruption du système ou des fichiers de données ;
- Le détournement de ressources (« vol de service ») pour transformer la machine en agent d'attaque (zombie) au sein d'un botnet ;
- Le vol d'informations sensibles (identifiants, mots de passe, données confidentielles) à l'aide de keyloggers ou d'outils d'espionnage.
- La furtivité, où le malware dissimule sa présence afin d'échapper aux mécanismes de détection et de blocage.

CLASSIFICATION DES LOGICIELS MALVEILLANTS

Remarque : Attaques mixtes (blended attacks)

Une attaque mixte combine plusieurs mécanismes d'infection ou de propagation afin d'augmenter à la fois la vitesse de contagion et l'impact de l'attaque.

Certains malwares intègrent en plus un mécanisme de mise à jour, leur permettant de modifier, après déploiement, leurs vecteurs de propagation et leurs charges utiles.

Dans les sections suivantes, nous détaillerons les principales catégories de logiciels malveillants, puis nous présenterons les contre-mesures adaptées.

PROPAGATION - CONTENU INFECTÉ - VIRUS

- La première grande catégorie de mécanismes de propagation regroupe les **fragments de logiciels parasites** qui s'attachent à un contenu exécutable existant. Ce fragment peut être :
 - code machine qui infecte une application,
 - un utilitaire, un programme système ou même le code de démarrage d'un ordinateur.
- Historiquement, les infections par **virus** constituaient la forme de malware la plus courante à l'époque des premiers ordinateurs personnels.

N.B. Par abus de langage, le terme « virus informatique » reste encore largement utilisé pour désigner l'ensemble des logiciels malveillants, et pas seulement les véritables virus.

PROPAGATION - CONTENU INFECTÉ - VIRUS

Nature des virus

- Un virus informatique est un programme capable d'infecter d'autres programmes, ou plus largement tout contenu exécutable, en les modifiant.
- Cette modification consiste à injecter dans le code légitime une routine qui crée des copies du virus, lesquelles pourront à leur tour infecter d'autres contenus exécutables.

PROPAGATION - CONTENU INFECTÉ - VIRUS

Virus et privilèges de l'utilisateur

- Un virus attaché à un exécutable s'exécute discrètement quand le programme hôte est lancé.
- Il peut alors effectuer toutes les actions autorisées à l'utilisateur courant (par exemple supprimer des fichiers).

PROPAGATION - CONTENU INFECTÉ - VIRUS

Virus classiques vs virus de macro

- Les systèmes modernes, avec des contrôles d'accès renforcés, limitent les infections par virus d'exécutables.
- Les attaquants se tournent donc vers les virus de macro, intégrés à des documents Word, Excel ou PDF facilement modifiés et échangés.

PROPAGATION - CONTENU INFECTÉ - VIRUS

Structure de virus

Un virus informatique comporte trois composants :

- **Mécanisme d'infection** : le moyen par lequel le virus se propage et se réplique (vecteur d'infection).
- **Déclencheur** : l'événement ou la condition qui active la charge utile (parfois appelé « bombe logique »).
- **Charge utile** : l'action réalisée par le virus en plus de sa propagation, allant de comportements gênants à des dommages importants sur le système ou les données.

PROPAGATION - CONTENU INFECTÉ - VIRUS

Phases de virus

Un virus passe en général par quatre phases :

1. **Phase dormante** : le virus reste inactif jusqu'à un événement déclencheur (date, présence d'un fichier/programme, etc.). Tous les virus n'ont pas forcément cette phase.
2. **Phase de propagation** : le virus se copie dans d'autres programmes ou zones du système disque. Les copies ne sont pas toujours identiques, mais chaque programme infecté contient un clone capable de se propager à son tour.

PROPAGATION - CONTENU INFECTÉ - VIRUS

Phases de virus

3. **Phase de déclenchement** : une condition spécifique (événement, date, compteur de répliquions, ...) active la charge utile.
4. **Phase d'exécution** : la charge utile s'exécute, avec un effet pouvant aller d'un simple message à l'écran à la destruction de programmes ou de fichiers de données.

PROPAGATION - CONTENU INFECTÉ - VIRUS

Classification des virus

Dans cette section, nous classons les virus selon deux axes indépendants :

- le type de **cible** qu'ils cherchent à infecter (fichiers, secteur de démarrage, macros, documents, etc.) ;
- la **méthode de dissimulation** qu'ils utilisent pour échapper à la détection (chiffrement, polymorphisme, furtivité, ...).

PROPAGATION - CONTENU INFECTÉ - VIRUS

Classification des virus : par cible

- **Virus du secteur d'amorçage (MBR)** : infecte l'enregistrement d'amorçage principal et se propage lorsqu'un système est démarré à partir du disque contaminé.
- **Virus de fichiers** : infecte les fichiers que le système ou le shell considèrent comme exécutables.
- **Virus de macro** : infecte les fichiers avec une macro ou un code de script interprété par une application.
- **Virus multipartite** : il est capable d'infecter plusieurs types de fichiers à la fois, de sorte que sa détection et son éradication devienne plus complexe.

PROPAGATION - CONTENU INFECTÉ - VIRUS

Classification des virus : par stratégie

- **Virus crypté :**

- Une partie du virus crée une clé de cryptage aléatoire et crypte le reste du virus. Cette clé est stockée avec le virus.
- Lorsqu'un programme infecté est lancé, le virus utilise la clé aléatoire pour se déchiffrer. Lorsque le virus se réplique, une clé aléatoire différente est sélectionnée.
- Comme la partie principale est chiffrée avec une clé différente à chaque instance, il n'existe pas de motif binaire fixe facile à détecter par signature.

PROPAGATION - CONTENU INFECTÉ - VIRUS

Classification des virus : par stratégie

- **Virus furtif :**

- Un virus furtif est conçu pour **se dissimuler** aux mécanismes de détection : ce n'est pas seulement sa charge utile qui est cachée, mais l'ensemble du code viral.
- Pour y parvenir, il peut utiliser diverses techniques comme la mutation de code (modification fréquente de sa forme), la compression/emballage, ou des mécanismes de type rootkit qui masquent sa présence dans le système.

PROPAGATION - CONTENU INFECTÉ - VIRUS

Classification des virus : par stratégie

- **Virus polymorphe :**

- Un virus polymorphe génère, à chaque réplication, des copies fonctionnellement identiques mais avec des modèles binaires différents, afin d'échapper aux signatures classiques des antivirus.
- Sa « signature » change donc à chaque nouvelle copie : pour cela, il peut insérer des instructions inutiles, réordonner des instructions indépendantes ou modifier systématiquement sa routine de déchiffrement.

PROPAGATION - CONTENU INFECTÉ - VIRUS

Classification des virus : par stratégie

- **Virus métamorphique :**

- Comme le virus polymorphe, le virus métamorphique mute à chaque infection, mais il va plus loin en réécrivant entièrement leur propre code à chaque itération, via de multiples techniques de transformation.
- Il peut ainsi modifier non seulement son apparence binaire, mais aussi certains aspects de son comportement, ce qui rend sa détection encore plus difficile.

PROPAGATION - EXPLOITATION DE LA VULNÉRABILITÉ - VERS

La deuxième grande catégorie de propagation repose sur l'**exploitation de vulnérabilités logicielles**, typiquement par les **vers**.

- Un ver (worm) est un programme qui recherche activement à infecter d'autres machines, puis chaque machine infectée sert de rampe de lancement automatisée pour d'autres attaques.
- Il exploite des failles dans des services client ou serveur pour pénétrer d'autres systèmes. Il se propage également via des connexions réseau ou des supports partagés, tels que des clés USB ou des disques de données.

PROPAGATION - EXPLOITATION DE LA VULNÉRABILITÉ - VERS

Moyens de réplique – e-mail / messagerie

Pour se répliquer, un ver doit atteindre d'autres systèmes distants.

Un premier vecteur courant est le **courrier électronique** ou la **messagerie instantanée** : le ver envoie automatiquement une copie de lui-même (ou un lien piégé) aux contacts de la victime, via e-mail ou services de chat, et son code s'exécute lorsque la pièce jointe est ouverte ou que le lien est consulté.

PROPAGATION - EXPLOITATION DE LA VULNÉRABILITÉ - VERS

Moyens de réplication – Partage de fichiers

Un ver copie son code ou infecte des fichiers sur un support amovible (clé USB, disque externe) puis s'exécute sur un autre système lorsque:

- le mécanisme d'exécution automatique est déclenché (ou une vulnérabilité est exploitée),
- ou qu'un utilisateur ouvre le fichier infecté sur la machine cible.

PROPAGATION - EXPLOITATION DE LA VULNÉRABILITÉ - VERS

Autres moyens de réplique

- **Exécution à distance** : le ver déclenche son code sur un système distant en exploitant une vulnérabilité dans un service réseau ou une fonctionnalité d'exécution distante.
- **Accès / transfert de fichiers à distance** : le ver se copie via un service de partage ou de transfert de fichiers (FTP, SMB, etc.), puis est exécuté manuellement ou automatiquement sur la machine cible.
- **Connexion à distance** : le ver se connecte à un autre système avec des identifiants (volés ou devinés), puis y exécute des commandes pour se répliquer et s'exécuter.

PROPAGATION - EXPLOITATION DE LA VULNÉRABILITÉ - VERS

Modèle de propagation des vers

- Un ver bien conçu peut se diffuser très rapidement et infecter un grand nombre d'hôtes. Pour analyser ce phénomène, on utilise des **modèles mathématiques** de propagation, similaires à ceux employés pour les virus biologiques.
- Les virus et les vers informatiques présentent un comportement d'auto-réplication et de propagation proche d'une épidémie.
- Ainsi, nous pouvons utiliser les **modèles épidémiques classiques** pour comprendre le comportement de propagation des virus et des vers informatiques.

PROPAGATION - EXPLOITATION DE LA VULNÉRABILITÉ - VERS

Modèle de propagation des vers

Un modèle épidémique classique simplifié peut être exprimé comme suit :

$$\frac{dI(t)}{dt} = \beta I(t) S(t)$$

Où :

$I(t)$: nombre d'individus infectés au temps t

$S(t)$: nombre d'individus sensibles (non encore infectés) au temps t

β : taux d'infection

N : taille de la population, $N = I(t) + S(t)$

PROPAGATION - INGÉNIERIE SOCIALE - EMAIL SPAM, TROJAN

Cette dernière catégorie de propagation repose sur l'**ingénierie sociale**, qui consiste à tromper les utilisateurs pour qu'ils compromettent eux-mêmes leurs systèmes ou leurs données.

Cela arrive par exemple lorsqu'un utilisateur ouvre un courriel indésirable et interagit avec son contenu (pièce jointe, lien, réponse), ou lorsqu'il autorise l'installation et l'exécution d'un cheval de Troie ou d'un script malveillant.

PROPAGATION - INGÉNIERIE SOCIALE - EMAIL SPAM, TROJAN

Spam (courrier indésirable)

L'essor d'Internet a favorisé l'apparition de courriers électroniques envoyés en masse et sans consentement, appelés spam.

Ce problème reste d'actualité : les attaquants utilisent désormais aussi d'autres canaux (réseaux sociaux, messageries, etc.) pour diffuser des messages non sollicités et piéger les utilisateurs.

PROPAGATION - INGÉNIERIE SOCIALE - EMAIL SPAM, TROJAN

Spam (courrier indésirable)

Les spams sont très souvent envoyés par des **botnets**.

La majorité de ces messages sont publicitaires et cherchent à pousser l'utilisateur à acheter un produit ou à visiter un site, souvent douteux.

Le spam est également un vecteur important de malwares:

- **Pièces jointes** qui installent du code malveillant à l'ouverture,
- Liens vers des **chevaux de Troie** ou des **scripts malveillants**,
- Messages **de phishing** (faux site, faux formulaire, ...).

PROPAGATION - INGÉNIERIE SOCIALE - EMAIL SPAM, TROJAN

Cheval de Troie

Un cheval de Troie est un programme en apparence légitime qui contient du code caché exécutant une action indésirable ou malveillante lorsqu'on le lance.

Il permet à l'attaquant d'accomplir indirectement des opérations qu'il ne pourrait pas réaliser directement sur la machine de la victime.

Par exemple, un utilitaire de nettoyage ou une mise à jour de logiciel contenant un cheval de Troie qui pourrait:

- Voler des informations sensibles,
- Activer une porte dérobée,
- Télécharger d'autres malwares ou installer un logiciel espion.

CHARGE UTILE - CORRUPTION DU SYSTÈME

Une fois le malware actif sur le système cible, la question centrale devient les actions qu'il va réaliser sur ce système, c'est-à-dire la **charge utile** qu'il transporte.

CHARGE UTILE - CORRUPTION DU SYSTÈME

Les charges utiles peuvent avoir plusieurs types de conséquences, qu'on peut regrouper ainsi :

➤ **Destruction de données / ransomware** : certains malwares effacent ou chiffrent les fichiers et parfois tout le système, puis exigent une rançon pour les restaurer. on peut citer par exemple :

- ***Chernobyl virus*** : plus d'un million d'ordinateurs touchés en Avril 1999.
- ***WannaCry*** : a infecté un grand nombre de systèmes dans de nombreux pays en mai 2017 en chiffrant un grand nombre de fichiers, puis en exigeant le paiement d'une rançon en Bitcoins.

CHARGE UTILE - CORRUPTION DU SYSTÈME

- **Dégât matériel** : cette variante de corruption du système vise à endommager les équipements physiques tel que les systèmes de contrôle industriel.
 - L'attaque de décembre 2015 contre le réseau électrique ukrainien, qui a provoqué de vastes coupures de courant, est un exemple de malware causant des dégâts matériels sur des systèmes industriels.

CHARGE UTILE - CORRUPTION DU SYSTÈME

- **Bombes logiques** : un code reste dormant jusqu'à ce qu'une condition soit remplie (date précise, présence/absence d'un fichier, nombre d'exécutions, etc.), puis déclenche soudain sa charge (effacement, chiffrement, sabotage).

CHARGE UTILE - AGENT D'ATTAQUE – ZOMBIE/BOT

- Cette charge utile prend le contrôle des ressources d'un système infecté pour les utiliser à des fins malveillantes.
- La machine compromise devient un **bot** (ou **zombie**) contrôlé à distance par l'attaquant, qui l'utilise pour lancer des attaques difficiles à tracer.
- Il peut s'agir d'ordinateurs, de serveurs ou d'appareils connectés comme des routeurs ou des caméras.
- Lorsqu'un grand nombre de ces machines sont infectées et coordonnées, on parle de **botnet**, un réseau capable d'attaques à grande échelle.

CHARGE UTILE - AGENT D'ATTAQUE – ZOMBIE/BOT

Utilisations des bots :

- Attaques par déni de service distribué (*DDoS*)
- *Spamming* : envoi massif d'e-mails non sollicités (spam).
- *Sniffing* : capture du trafic réseau pour récupérer des infos sensibles (identifiants, mots de passe, etc.).
- Keylogging : enregistrement des frappes clavier pour voler des données confidentielles.
- Diffusion de malwares : téléchargement et exécution de nouveaux logiciels malveillants (par exemple via HTTP ou FTP) pour étendre le botnet.

CHARGE UTILE - VOL D'INFORMATIONS - KEYLOGGERS & PHISHING

- Dans cette catégorie de charge utile, le malware a pour but principal de collecter des données présentes sur le système infecté, puis de les transmettre à l'attaquant.
- Les identifiants de connexion (**login** et **mot de passe**) sont une cible privilégiée, car ils permettent à l'attaquant de se faire passer pour la victime et d'accéder à ses comptes, souvent pour des gains financiers.
- Les informations volées peuvent ensuite servir à réaliser des fraudes, vider des comptes bancaires ou mener d'autres activités illégales en ligne.

CHARGE UTILE - VOL D'INFORMATIONS - KEYLOGGERS & PHISHING

Vol d'informations et enregistreurs de frappe

- En temps normal, les utilisateurs envoient leurs identifiants et mots de passe via des canaux chiffrés (HTTPS, POP3S, etc.), ce qui les protège d'une simple capture de paquets réseau.
- Avec un enregistreur de frappe (keylogger) installé sur la machine, l'attaquant peut toutefois recevoir une copie de tout ce qui est tapé au clavier.
- Le keylogger peut filtrer ces frappes et n'envoyer que les informations sensibles contenant, par exemple, les mots-clés « login », « password » ou « paypal.com ».

CHARGE UTILE - VOL D'INFORMATIONS - KEYLOGGERS & PHISHING

Hameçonnage et usurpation d'identité

- Un attaquant envoie un e-mail piégé avec un lien vers un faux site ou un formulaire à remplir.
- La victime y saisit ses identifiants ou ses données personnelles, qui sont alors récupérés par l'attaquant.
- Avec ces informations, celui-ci peut usurper son identité et accéder à ses comptes ou à d'autres services sensibles.
- Ce procédé s'appelle l'hameçonnage (phishing) et repose sur la tromperie de l'utilisateur.

CHARGE UTILE - FURTIVITÉ - PORTES DÉROBÉES, ROOTKITS

Cette dernière catégorie de charge utile regroupe les techniques qui permettent au malware de cacher sa présence sur le système et d'offrir un accès secret à l'attaquant.

En modifiant en profondeur le système, ces mécanismes portent aussi atteinte à son **intégrité**.

CHARGE UTILE - FURTIVITÉ - PORTES DÉROBÉES, ROOTKITS

Porte dérobée

- Une porte dérobée (backdoor) est un point d'entrée caché dans un programme qui permet à quelqu'un qui la connaît d'y accéder sans suivre les mécanismes de sécurité normaux.
- Les programmeurs peuvent en créer pour faciliter le débogage ou les tests, par exemple en ajoutant un code dans le programme de connexion qui autorise l'accès même sans utiliser les mots de passe enregistrés.

CHARGE UTILE - FURTIVITÉ - PORTES DÉROBÉES, ROOTKITS

Rootkit

- Un rootkit est un logiciel malveillant qui donne à un attaquant un accès caché au système avec des privilèges élevés (administrateur/root).
- Il modifie le système d'exploitation pour masquer ses fichiers et processus, ce qui rend sa détection difficile.
- Une fois installé, il peut contrôler la machine, espionner l'activité ou installer d'autres portes dérobées.

CHARGE UTILE - FURTIVITÉ - PORTES DÉROBÉES, ROOTKITS

Rootkit

Un rootkit peut être classé selon ses caractéristiques :

- **Persistant** : il se relance à chaque démarrage. Son code est stocké dans une zone persistante (registre, système de fichiers, firmware, etc.), ce qui permet parfois de le détecter en analysant ces traces.
- **Basé sur la mémoire** : il ne laisse pas de code persistant et disparaît au redémarrage, mais comme il ne réside qu'en mémoire vive, il est souvent plus difficile à repérer.

CHARGE UTILE - FURTIVITÉ - PORTES DÉROBÉES, ROOTKITS

Rootkit

- **Basé sur une machine virtuelle** : Ce type de rootkit installe un hyperviseur léger, puis fait tourner le système d'exploitation dans une machine virtuelle située au-dessus.

Il peut alors intercepter et modifier les événements du système virtuel tout en restant presque invisible pour l'utilisateur et les outils de sécurité.

LES CONTRE-MESURES

Il existe plusieurs approches de lutte contre les programmes malveillants.

La meilleure protection est la **prévention**, c'est-à-dire empêcher leur infiltration ou leur exécution sur le système.

Bien qu'une protection totale soit difficile à atteindre, l'adoption de contre-mesures adaptées permet de **réduire significativement** le risque d'infection.

LES CONTRE-MESURES

- i. L'une des premières contre-mesures à mettre en œuvre est de s'assurer que tous les systèmes sont aussi récents que possible, avec tous les correctifs appliqués, afin de réduire le nombre de vulnérabilités susceptibles d'être exploitées.
 - ii. La deuxième mesure consiste à mettre en place des contrôles d'accès appropriés sur les applications et les données stockées sur le système, afin de réduire le nombre de fichiers auxquels un utilisateur peut accéder, et donc potentiellement infecter ou corrompre.
- ➔ Ces mesures ciblent directement les principaux mécanismes de propagation utilisés par les vers, les virus et certains chevaux de Troie.

LES CONTRE-MESURES

- iii. Le troisième mécanisme de propagation qui cible les utilisateurs dans le cadre d'une attaque d'ingénierie sociale, peut être contrôlé par une sensibilisation et une formation appropriée des utilisateurs.

Cela vise à rendre les utilisateurs plus conscients de ces attaques et moins enclins à prendre des mesures qui aboutissent à leur compromission.

LES CONTRE-MESURES

Si la prévention échoue, des mécanismes techniques peuvent être utilisés pour atténuer les menaces :

- ✓ **Détection** : repérer la présence du logiciel malveillant après infection.
- ✓ **Identification** : une fois la détection effectuée, identifiez le logiciel malveillant qui a infecté le système.
- ✓ **Suppression** : une fois que le logiciel malveillant spécifique a été identifié, éliminer toutes ses traces pour stopper sa propagation.

LES CONTRE-MESURES

Remarque :

Si la détection réussit mais que l'identification ou la suppression n'est pas possible, l'alternative consiste à supprimer tous les fichiers suspects et à restaurer une sauvegarde saine.

Pour certaines infections particulièrement désagréables, cela peut nécessiter un nettoyage complet du stockage et une réinstallation à partir de supports fiables.

LES CONTRE-MESURES

Exigences pour des contre-mesures efficaces :

- ❖ **Généralité** : couvrir un large éventail de types d'attaques.
- ❖ **Rapidité** : réagir vite pour limiter la propagation et les dégâts.
- ❖ **Résilience** : résister aux techniques d'évasion employées par les attaquants pour dissimuler les logiciels malveillants.
- ❖ **Faible impact** : ne pas trop dégrader les performances ni perturber le service.
- ❖ **Transparence** : s'intégrer sans changements majeurs aux systèmes, applis ou matériels existants.

MERCI POUR VOTRE ATTENTION.

RÉFÉRENCES:

- [1] Andrew Tanenbaum, « Systèmes d'exploitation » (Ed. 3). Pearson Education (2008).
- [2] William Stallings & Lawrie Brown, « Computer Security - Principles and Practice » Pearson Education Limited (2018).